PediForm Pro

Pediatric Digital Forms Platform

Complete Product Design & Development Specification

Version 1.0 | For Junior Developer Handoff | Ready-to-Build

1. Product Overview & Clinical Context

PediForm Pro is a mobile-first, browser-based digital intake platform purpose-built for Pediatric Primary Care practices in the United States. Parents and guardians complete standardized forms before or during a visit using any device — phone, tablet, or desktop. Practice staff access a secure portal to download completed responses in structured formats.

1.1 The Clinical Problem We Are Solving

Pediatric offices run on tightly scripted visit workflows. The 'right' paperwork depends on two variables only: the child's age (in months and years) and the visit type. Getting this wrong wastes clinical time, creates compliance gaps, and frustrates families. Here is how it works in the real world:

Visit Type	Age Range	Forms Required	Notes
New Patient	Birth – 17y 11m	New Patient Paperwork	Always required for new patients regardless of age
Well Child (WCC)	2, 4, 6, 9, 12, 15, 18, 24, 30 mo	New Pt (if new) + ASQ	ASQ version matched to exact age in months
Well Child (WCC)	18 months & 24 months	New Pt (if new) + ASQ + M-CHAT-R	M-CHAT required by AAP at these two ages
Well Child (WCC)	2 years – 5 years	New Pt (if new) + ASQ	ASQ-3 used through age 5.5
Sick Visit	Any	None (standard)	No developmental screening at sick visits
Follow-up	Any	None (standard)	Only if requested by practice

1.2 Form Inventory

The system manages three categories of forms, all evidence-based and standard in US pediatric primary care:

Form Category	Full Name	Purpose
New Patient	New Patient Registration & Medical History	Demographics, insurance, medical/family/social history, allergies, medications, consent signatures
ASQ-3	Ages & Stages Questionnaire (3rd Ed.)	Developmental screening in 5 domains: Communication, Gross Motor, Fine Motor, Problem Solving, Personal-Social
ASQ:SE-2	Ages & Stages Questionnaire: Social-Emotional	Behavioral/social-emotional screening, used at specific ages alongside ASQ-3
M-CHAT-R	Modified Checklist for Autism in Toddlers, Revised	Autism screening tool, mandatory at 18 and 24 month well child visits per AAP guidelines

1.3 ASQ Age-Band Mapping (Critical Clinical Logic)

The ASQ-3 has discrete questionnaires for specific age bands. The system must compute the child's exact age in months at the time of visit and serve the correct version. This is the most important business logic in the entire system.

ASQ-3 Version	Age Range	Also Include ASQ:SE-2?	M-CHAT-R?
2 Month	1 month 0 days – 2 months 30 days	No	No
4 Month	3m 0d – 4m 30d	No	No
6 Month	5m 0d – 6m 30d	Yes (6 mo SE-2)	No
8 Month	7m 0d – 8m 30d	No	No
10 Month	9m 0d – 10m 30d	No	No
12 Month	11m 0d – 12m 30d	Yes (12 mo SE-2)	No
14 Month	13m 0d – 14m 30d	No	No
16 Month	15m 0d – 16m 30d	No	No
18 Month	17m 0d – 18m 30d	Yes (18 mo SE-2)	YES – REQUIRED
20 Month	19m 0d – 20m 30d	No	No
22 Month	21m 0d – 22m 30d	No	No
24 Month	23m 0d – 24m 30d	Yes (24 mo SE-2)	YES – REQUIRED
27 Month	25m 0d – 28m 30d	No	No
30 Month	29m 0d – 32m 30d	Yes (30 mo SE-2)	No
33 Month	33m 0d – 35m 30d	No	No
36 Month	36m 0d – 41m 30d	Yes (36 mo SE-2)	No
42 Month	42m 0d – 47m 30d	Yes (42 mo SE-2)	No
48 Month	48m 0d – 53m 30d	Yes (48 mo SE-2)	No
54 Month	54m 0d – 59m 30d	Yes (54 mo SE-2)	No
60 Month	60m 0d – 65m 30d (5 yrs)	Yes (60 mo SE-2)	No
66 Month	66m+ (up to 5.5 yrs)	No	No

Note: ASQ screening is only done at well child visits. Do NOT present ASQ or M-CHAT at sick or follow-up visits. The system must prompt for visit type before displaying any forms.

2. System Architecture

2.1 High-Level Architecture

The system has two distinct surfaces: the Parent Portal (public-facing, mobile-first) and the Staff Portal (password-protected, desktop-optimized). They share a common backend API and database.

Frontend – Parent	React 18 + Vite, Tailwind CSS, mobile-first responsive, hosted on Vercel or Netlify
Frontend – Staff	Same React app, separate route /staff, protected by auth middleware
Backend API	Node.js + Express (or Next.js API routes), RESTful endpoints, JWT authentication
Database	PostgreSQL (Supabase recommended for quick setup) — stores submissions, practices, sessions
File Generation	Server-side PDF generation using pdf-lib or Puppeteer for staff downloads
Authentication	Supabase Auth for staff login; parent sessions are stateless (no login required)
Hosting	Vercel (frontend) + Railway or Render (backend API) + Supabase (DB)
Storage	Supabase Storage or AWS S3 for generated PDF downloads

2.2 Database Schema

Table: practices

Column	Type	Notes
id	UUID (PK)	Auto-generated
name	VARCHAR(200)	Practice display name
slug	VARCHAR(100)	URL-safe identifier e.g. 'sunshine-pediatrics'
logo_url	TEXT	Optional practice logo for branding
settings	JSONB	Feature flags, enabled form types, etc.
created_at	TIMESTAMPTZ	Auto-set

Table: submissions

Column	Type	Notes
id	UUID (PK)	Auto-generated
practice_id	UUID (FK)	References practices.id
child_first_name	VARCHAR(100)	
child_last_name	VARCHAR(100)	
child_dob	DATE	Used to compute age at time of submission
child_age_months	INTEGER	Computed at submission time and stored
visit_type	ENUM	'new_patient', 'well_child', 'sick', 'follow_up'

Column	Type	Notes
forms_completed	TEXT[]	Array of form IDs completed in this session
form_data	JSONB	All form responses keyed by form_id
confirmation_code	VARCHAR(20)	Human-readable code shown to parent on completion
status	ENUM	'in_progress', 'completed', 'downloaded'
submitted_at	TIMESTAMPTZ	Set when parent hits Submit
ip_address	INET	For audit trail
downloaded_at	TIMESTAMPTZ	Set when staff first downloads
downloaded_by	UUID (FK)	Staff user who downloaded

3. Parent Portal — Full UX Flow & Screen Specifications

3.1 Design Principles for Parent-Facing UI

- Mobile-first. Design for a stressed parent sitting in a waiting room, on a phone, possibly holding an infant.
- One thing at a time. Never show more than one major input per screen or card. Use a wizard/stepper pattern.
- Plain language. No clinical jargon. No acronyms. 'Your child's development' not 'ASQ-3 administration'.
- Progress visibility. Always show a top progress bar with step numbers.
- Auto-save. Save to sessionStorage every 30 seconds. If parent closes browser and reopens within 2 hours, offer to restore progress.
- Large touch targets. All buttons minimum 48px tall. Form fields minimum 44px tall.
- Clear error states. Inline validation in red below the field that failed. Never a generic error modal.
- Accessible. WCAG 2.1 AA compliance. Support for screen readers, high contrast, and font scaling.

3.2 URL Structure

Each practice gets a unique URL. Parents access this via a QR code at the front desk or a link in a text/email reminder:

```
https://app.pediformpro.com/p/{practice-slug}
```

Example: https://app.pediformpro.com/p/sunshine-pediatrics

3.3 Step-by-Step Screen Specifications

SCREEN 1: Welcome & Child Lookup

Route	/p/{slug}
Purpose	Identify the child and visit type to determine which forms to show
Layout	Single centered card, max-width 480px, white card on light blue/grey background
Practice Logo	Display practice logo at top of card if configured, otherwise practice name as text

Fields on this screen:

- Child's First Name (text input, required)
- Child's Last Name (text input, required)
- Child's Date of Birth (date picker, required — with manual entry fallback: MM/DD/YYYY)
- Today's Visit Type (dropdown, required): New Patient | Well Child Check | Sick Visit | Follow-Up

On clicking 'Continue':

- Compute age in months: Math.floor(days since DOB / 30.44)
- Determine which forms are needed based on visit type + age (see Section 1.3 logic)
- Create a submission record in DB with status = 'in_progress'
- Navigate to Screen 2 — Form Overview

> ⚡ **Note:** Do NOT validate insurance or lookup patient records. This is an intake system only — no EMR integration in v1.

SCREEN 2: Form Overview / What to Expect

Route	/p/{slug}/session/{session_id}/overview
Purpose	Show parent what forms they will complete. Set expectations. Reduce abandonment.
Layout	Same card layout. List the forms to complete with estimated time for each.

Display a checklist of forms to complete. Example for a new 18-month-old patient:

- New Patient Paperwork (est. 8–10 min)
- Child Development Questionnaire — 18 Months (est. 5 min)
- Social-Emotional Development — 18 Months (est. 3 min)
- Toddler Development Screening (est. 3 min)

Primary CTA button: 'Start Paperwork →'

SCREEN 3–N: Form Wizard (One Form at a Time)

Route	/p/{slug}/session/{id}/form/{form_id}/step/{step}
Pattern	Multi-step wizard within each form. Sections within the form are broken into logical steps.
Progress	Two-tier progress: Form N of N (top) + Step N of N within current form (sub-bar)
Navigation	Back / Next buttons at bottom. Back is grey/ghost, Next is primary blue. Disable Next until required fields on current step are valid.
Auto-save	POST /api/submissions/{id}/autosave every 30 seconds with current form data

New Patient Paperwork — Steps breakdown:

- Step 1: Child Information — Full name, DOB (pre-filled and read-only), sex, race/ethnicity, preferred language
- Step 2: Parent / Guardian 1 — Full name, relationship, phone, email, address, employer, SSN (optional)
- Step 3: Parent / Guardian 2 — Same fields, with option 'Only one guardian'
- Step 4: Insurance — Primary insurance: company, subscriber name, subscriber DOB, group #, member ID. Option to add secondary.
- Step 5: Pharmacy — Preferred pharmacy name, address/zip (with autocomplete)
- Step 6: Medical History — Birth history (gestational age, birth weight, complications), prior hospitalizations, prior surgeries
- Step 7: Current Concerns — Free text 'What brings you in today?' + 'Any concerns about development?'
- Step 8: Allergies — Drug allergies (name + reaction). Food allergies. Environmental allergies. Option: 'No known allergies'
- Step 9: Current Medications — Medication name, dose, frequency. Option: 'Not on any medications'
- Step 10: Immunization History — 'Up to date', 'Partial', 'Unvaccinated', 'Not sure'
- Step 11: Family History — Diabetes, heart disease, hypertension, cancer, mental health conditions, other. Checkboxes.
- Step 12: Social History — Household members (# adults, # children), smokers in home, pets, daycare/school, nutrition (breastfed/formula/table food)

- Step 13: Provider Preference — Any physician preference within practice, how did you hear about us, referring provider
- Step 14: Consent & Signature — Display consent language. 'I agree' checkbox. Signature pad (finger/mouse draw). Legal name typed. Date auto-filled.

ASQ-3 Form — Structure:

- Header (non-counted step): Explain to parent what ASQ is, how long it takes, note 'there are no right or wrong answers'
- Each domain is one step: Communication (6 Q's), Gross Motor (6 Q's), Fine Motor (6 Q's), Problem Solving (6 Q's), Personal-Social (6 Q's)
- Each question: large text, 3 big radio button options: 'Yes' (10 pts), 'Sometimes' (5 pts), 'Not Yet' (0 pts)
- Final step: Overall Questions — 4–6 open-ended concern questions, free text
- Scoring computed automatically server-side on submission

M-CHAT-R Form — Structure:

- Header: Brief explanation in parent-friendly language. 'This helps us check your child's social development.'
- 20 Yes/No questions presented one at a time (or 5 per page — configurable per practice)
- Large YES / NO buttons, minimum 60px tall, full width on mobile
- Progress: 'Question X of 20'
- No free text in M-CHAT-R standard form
- If score >= 3 (positive screen), flag in DB. Practice staff will see this highlighted in their portal.

SCREEN (Final): Confirmation

Route	/p/{slug}/session/{id}/confirmation
Purpose	Confirm completion. Provide reference code. Reduce parent anxiety.
Layout	Large green checkmark icon at top. Friendly confirmation message.

Display:

- 'Thank you, [Parent Name]! [Child Name]'s paperwork is complete.'
- Confirmation code in large, copyable text — e.g. 'SPK-2024-4821'
- 'Please show this code to the front desk.' (or 'No action needed — we have received your forms.')
- Option to print this page (CSS print media query)
- DO NOT show a 'Start Over' button. The form is done.

4. Staff Portal — Specifications

4.1 Authentication

- Staff login at /staff/login — email + password via Supabase Auth
- Each practice has its own staff accounts. A staff account belongs to one practice only.
- Roles: Admin (can manage staff accounts) and Staff (read + download only)
- Session timeout after 60 minutes of inactivity
- No self-registration — Admin creates staff accounts from within the portal

4.2 Staff Dashboard — Screen Spec

Route	/staff/dashboard
Default view	Today's submissions, newest first
Columns shown	Time Submitted | Child Name | DOB | Age | Visit Type | Forms Completed | Status | Actions
Status badges	In Progress (yellow), Completed (green), Downloaded (grey)
Filters	Date range picker, Visit Type dropdown, Status filter, Name search
Pagination	25 rows per page, with total count shown

4.3 Submission Detail View

Clicking any row opens a detail panel (slide-over or dedicated page) showing:

- Child demographics summary at the top
- Tabbed view: one tab per form completed
- ASQ and M-CHAT tabs show responses AND computed scores with color-coded interpretation (green = below cutoff, yellow = near cutoff, red = above cutoff / positive screen)
- M-CHAT positive screens shown with a prominent red alert banner

4.4 Download Functionality

Each submission can be downloaded in two formats:

- PDF — A formatted, branded PDF replicating the paper form layout. One PDF per submission (all forms combined).
- CSV — A flat export with all fields. Used for importing into EMR systems.

Download button states:

- 'Download PDF' — always available for completed submissions
- 'Download CSV' — always available for completed submissions
- 'Bulk Download' — select multiple rows with checkboxes, download as ZIP of PDFs

4.5 Practice Settings (Admin Only)

- Update practice name and logo
- Configure which visit types are enabled

- Manage staff accounts (invite, deactivate, reset password)
- View QR code for parent portal URL (for printing/laminating at front desk)
- Customize consent text for new patient form

5. API Endpoints — Full Reference

5.1 Public Endpoints (No Auth — Parent-Facing)

Method	Endpoint	Description	Key Behavior
GET	/api/practices/:slug	Get practice config	Returns name, logo, enabled form types. 404 if not found.
POST	/api/submissions	Create new session	Body: {practice_id, child_first_name, child_last_name, child_dob, visit_type}. Returns session_id, forms_to_complete array, confirmation_code.
PATCH	/api/submissions/:id/autosave	Auto-save progress	Body: {form_id, step, data}. Merges into form_data JSONB. Returns 200.
POST	/api/submissions/:id/complete	Mark as complete	Validates all required forms are done. Sets status=completed, submitted_at=now. Returns confirmation screen data.

5.2 Protected Endpoints (Staff Auth Required)

Method	Endpoint	Description	Key Behavior
GET	/api/staff/submissions	List submissions	Query params: date_from, date_to, status, visit_type, search. Returns paginated list.
GET	/api/staff/submissions/:id	Get full detail	Returns all form_data + computed scores for ASQ and M-CHAT.
GET	/api/staff/submissions/:id/pdf	Download PDF	Generates and streams PDF. Sets downloaded_at timestamp.
GET	/api/staff/submissions/:id/csv	Download CSV	Returns flat CSV of all submission fields.
POST	/api/staff/bulk-download	Bulk PDF download	Body: {submission_ids:[]}. Returns ZIP stream.
GET	/api/staff/practice	Get practice settings	Admin only: full practice config.
PATCH	/api/staff/practice	Update settings	Admin only: update name, logo, consent text.
GET/POST/DELETE	/api/staff/users	Manage staff	Admin only: CRUD for staff accounts.

5.3 Form Selection Logic — Backend Pseudocode

This is the most critical function in the entire codebase. It must be on the server to prevent manipulation:

```
function determineFormsToComplete(childDob, visitType) {
  const ageInMonths = getAgeInMonths(childDob, new Date());
  const forms = [];
  if (visitType === 'new_patient') {
    forms.push('new_patient_paperwork');
```

```
  }
  if (visitType === 'well_child' || visitType === 'new_patient') {
    const asqVersion = getASQVersion(ageInMonths); // see mapping table
    if (asqVersion) forms.push(`asq3_${asqVersion}mo`);
    if (needsASQSE2(ageInMonths)) forms.push(`asqse2_${asqVersion}mo`);
    if (ageInMonths >= 16 && ageInMonths <= 30) {
      // M-CHAT required at 18mo and 24mo visits
      if (isCloseTo(ageInMonths, 18) || isCloseTo(ageInMonths, 24)) {
        forms.push('mchat_r');
      }
    }
  }
  return forms;
}
```

6. AI-Assisted Development Strategy (Vibe Coding Guide)

This section is a hands-on guide for using OpenAI Codex, GitHub Copilot, or Claude as a coding co-pilot to build PediForm Pro efficiently. Follow the workflow below precisely — AI tools produce dramatically better code when given structured context.

6.1 Recommended Toolchain

Tool	Purpose
Claude (claude.ai)	Architecture decisions, complex logic (ASQ routing), debugging, code review, generating test cases
GitHub Copilot	In-editor autocomplete for boilerplate, React components, API handlers
Cursor IDE	AI-native editor — paste this entire spec into Cursor's project context for best results
v0 by Vercel (v0.dev)	Generate initial UI components from descriptions — export to React/Tailwind
Supabase	Auto-generates TypeScript types from your DB schema — no hand-writing interfaces

6.2 Project Setup Prompt (Use This First)

Feed this to Claude or paste into Cursor's context window at project start:

```
I am building a pediatric digital forms platform called PediForm Pro. Stack: React 18 +
Vite, Tailwind CSS, Node.js/Express backend, PostgreSQL via Supabase, pdf-lib for PDF
generation, Supabase Auth for staff. The app has two surfaces: a parent-facing form
wizard (mobile-first, no login) and a staff portal (desktop, auth required). The most
critical logic is an age-based form routing function that determines which forms to show
based on child's age in months and visit type. I will give you tasks one at a time.
Always write TypeScript. Always add JSDoc comments to functions. Always write unit tests
for business logic.
```

6.3 Component-by-Component AI Prompts

Use these exact prompts with Claude or Copilot. Start a fresh chat for each component.

Prompt 1: Age Calculation & Form Routing Logic

```
Write a TypeScript module called formRouter.ts. Export a function getAgeInMonths(dob:
Date, visitDate: Date): number that computes exact age in months. Export a function
getFormsToComplete(dob: Date, visitType: 'new_patient'|'well_child'|'sick'|'follow_up',
visitDate?: Date): FormAssignment[] that returns an ordered array of form IDs and display
names based on the AAP ASQ-3 age band mapping. The ASQ bands are: 2mo (1m0d-2m30d), 4mo
(3m0d-4m30d), 6mo (5m0d-6m30d), 8mo (7m0d-8m30d), 10mo (9m0d-10m30d), 12mo (11m0d-
12m30d), 14mo, 16mo, 18mo, 20mo, 22mo, 24mo, 27mo, 30mo, 33mo, 36mo, 42mo, 48mo, 54mo,
60mo, 66mo. ASQ:SE-2 is added at 6, 12, 18, 24, 30, 36, 42, 48, 54, 60 months. M-CHAT-R
is added at 18 and 24 months only. Write comprehensive Jest unit tests covering edge
cases (child exactly at band boundary, sick visit returns empty array, new patient gets
paperwork but no ASQ). Include full TypeScript types.
```

Prompt 2: Multi-Step Form Wizard Component

```
Create a React component FormWizard.tsx using Tailwind CSS. It accepts: steps (array of
step configs with title, fields, validationSchema using Zod), onStepComplete (callback),
onFormComplete (callback), autoSaveCallback (async function called every 30 seconds with
current data). Show a progress bar at the top with step count. Each step renders its
fields using react-hook-form. Validate on Next click and show inline errors below each
field. Show Back/Next buttons. On final step show Submit. The component must be mobile-
first — max-width 480px centered, generous padding, large touch targets (min-height 48px
on all interactive elements). Use Tailwind only, no custom CSS.
```

Prompt 3: Staff Dashboard Table

```
Create a React component SubmissionsTable.tsx with Tailwind CSS. It fetches from GET
/api/staff/submissions with query params {date_from, date_to, status, search}. Display
columns: Time, Child Name, Age (in months + years), Visit Type, Forms Completed (as pill
badges), Status (color-coded badge: yellow=in_progress, green=completed,
grey=downloaded), Download (PDF and CSV buttons). Add a bulk-select checkbox column. A
'Bulk Download' button appears when rows are selected. Add date range filter inputs and a
status dropdown filter at the top. Highlight rows in red where M-CHAT was positive.
Paginate at 25 rows. Use SWR or TanStack Query for data fetching with 60-second polling.
```

Prompt 4: Supabase Schema & RLS Policies

```
Write the complete Supabase SQL migration file to create tables: practices (id uuid pk,
name text, slug text unique, logo_url text, settings jsonb, created_at timestamptz),
submissions (id uuid pk, practice_id uuid references practices, child_first_name text,
child_last_name text, child_dob date, child_age_months integer, visit_type text check in
('new_patient','well_child','sick','follow_up'), forms_completed text[], form_data jsonb,
confirmation_code text unique, status text check in
('in_progress','completed','downloaded'), submitted_at timestamptz, ip_address inet,
downloaded_at timestamptz, downloaded_by uuid), staff_users (id uuid pk references
auth.users, practice_id uuid references practices, role text check in ('admin','staff'),
is_active boolean). Add Row Level Security: staff can only SELECT submissions where
practice_id matches their own practice_id. Public (unauthenticated) can INSERT and PATCH
submissions but cannot SELECT them. Generate TypeScript types for all tables using
Supabase type generation syntax.
```

Prompt 5: PDF Generation

```
Write a Node.js TypeScript module pdfGenerator.ts using the pdf-lib package. Export an
async function generateSubmissionPDF(submission: SubmissionRecord): Promise<Buffer>. The
PDF should: 1) Have a header with practice name and logo (if logo_url exists, fetch and
embed it). 2) For the New Patient form, render each section as labeled rows with
responses. 3) For ASQ-3, show each domain's questions and responses in a table, and show
the computed domain score vs the cutoff score at the bottom of each domain. 4) For M-
CHAT-R, show each question numbered with Yes/No response highlighted. Show total score
and risk level (Low < 3, Medium 3-7, High > 7) in a colored box. 5) Add page numbers and
a footer with practice name and 'Generated by PediForm Pro'. Use Helvetica. Page size US
Letter.
```

6.4 AI Workflow Rules for the Development Team

- Always give the AI the full TypeScript interface for any data structure before asking it to write code that uses it. Copy-paste from your types/ folder.
- When the AI generates a function, immediately ask: 'Write Jest unit tests for this function covering happy path and 3 edge cases.' Do this before moving on.
- For UI components, always add: 'Make this component WCAG 2.1 AA accessible — add aria-labels, ensure keyboard navigation works, and add focus ring styles.'
- Use Claude for debugging sessions: paste your error + full stack trace + the relevant 50 lines of code. Do not just paste the error.

- After generating a complex component, ask: 'What are the top 3 ways this component could fail in production on a slow 3G mobile connection?'
- Do not ask the AI to 'build the whole app'. Break every task down to a single file or function. The smaller the task, the higher the quality of output.

6.5 v0.dev Prompts for UI Scaffolding

Use these on v0.dev to generate Tailwind + React UI that you then connect to your backend:

- 'Create a mobile-first multi-step form wizard with a blue progress bar at the top, white card on a light blue background, large Next/Back buttons at the bottom. Step 1 has fields: First Name, Last Name, Date of Birth (date picker), Visit Type (select dropdown). All inputs are minimum 48px tall. Show validation errors inline in red below the field.'
- 'Create a data table for a staff dashboard. Columns: checkbox, Time, Child Name, Age, Visit Type, Status badge (color coded), Download buttons. The table has a filter bar at the top with a date range picker and status dropdown. Rows with status red are highlighted with a light red background. Responsive on desktop only.'

6.6 Testing Strategy

Test Type	Tool	What to Test
Unit Tests	Jest + ts-jest	formRouter logic (every age band boundary), ASQ scoring, M-CHAT scoring, PDF data transformation
Integration Tests	Jest + Supertest	All API endpoints — happy path and auth failure cases
E2E Tests	Playwright	Full parent flow: enter child info → complete all forms → see confirmation. Staff flow: login → view submission → download PDF.
Accessibility	axe-playwright	Run axe on every page in the parent portal. Zero critical violations required.
Load Testing	k6	Simulate 50 concurrent parents submitting forms. API must respond in < 500ms.

7. Security & Compliance Requirements

7.1 HIPAA Considerations

While a full HIPAA Business Associate Agreement (BAA) is out of scope for v1, the following baseline protections are required:

- All data in transit: HTTPS/TLS 1.3 enforced, no HTTP.
- All data at rest: Supabase encrypts at rest by default (AES-256).
- No PHI in logs: Ensure logging middleware strips child names, DOBs from all server logs.
- Access control: Row-level security ensures practices can only see their own patient data.
- Audit trail: Log all staff access and downloads with timestamp and user ID.
- Data retention: Implement automatic deletion of submissions older than 90 days (configurable per practice).

> ⚡ **Note:** Before going to production with a paying practice, obtain a BAA from Supabase and consult with a healthcare attorney regarding HIPAA compliance.

7.2 Input Validation & Security

- All API inputs validated with Zod schemas server-side. Client-side validation is UX only.
- SQL injection: Supabase parameterized queries prevent injection by default.
- Rate limiting: Apply express-rate-limit — max 10 submissions per IP per hour.
- CSRF: Use CSRF tokens for all state-mutating POST/PATCH requests.
- Content Security Policy headers on all responses.
- The confirmation code must not be guessable — use crypto.randomBytes(4).toString('hex').

8. Deployment & Infrastructure

8.1 Recommended Infrastructure Stack

Frontend	Vercel — connect GitHub repo, automatic deploys on push to main
Backend API	Railway.app — Node.js service, environment variables managed in Railway dashboard
Database	Supabase — managed PostgreSQL, includes Auth, Storage, and auto-generated APIs
File Storage	Supabase Storage — for practice logos and generated PDF cache
Domain	Custom domain on Vercel. Use practice.pediformpro.com or custom domain per practice in v2.
CI/CD	GitHub Actions — run Jest tests on every PR. Block merge if tests fail.
Monitoring	Sentry for error tracking (free tier). Vercel Analytics for page load metrics.

8.2 Environment Variables

```
# Backend .env
SUPABASE_URL=https://xxxx.supabase.co
SUPABASE_SERVICE_ROLE_KEY=xxx  # Never expose this to client
JWT_SECRET=<random 64-char string>
ALLOWED_ORIGINS=https://app.pediformpro.com

# Frontend .env (prefix with VITE_)
VITE_SUPABASE_URL=https://xxxx.supabase.co
VITE_SUPABASE_ANON_KEY=xxx  # Safe to expose
VITE_API_BASE_URL=https://api.pediformpro.com
```

8.3 Launch Checklist

- All Jest unit tests passing with 0 failures
- Playwright E2E passing for parent and staff flows on Chrome, Safari, and Firefox
- axe accessibility tests: 0 critical violations on all parent-facing pages
- Mobile test on real iPhone (Safari) and Android (Chrome) — not just browser DevTools
- Test QR code workflow: print QR code, scan with phone, complete full form
- Staff portal tested on desktop Chrome and Safari
- PDF download tested: open in Adobe Reader, Apple Preview, and browser PDF viewer
- Load test: 50 concurrent users, all endpoints < 500ms p95
- Error monitoring: Sentry configured and receiving test events
- Verify no PHI appears in browser console logs or network tab URLs

END OF SPECIFICATION